

T0.3 — Meta webhook signature obligatorio

Resumen de implementacion · Fecha: 2026-05-01 · Sin merge, sin deploy. · Rama lista para revision.

Implementado y testeado. 3 archivos modificados, 455 tests verde, branch *pr/meta-webhook-firma-obligatoria* en GitHub. Riesgo P0 cerrado: con WHATSAPP_PROVIDER=meta en produccion ya no se aceptan webhooks sin firma HMAC valida. Queda T0.10 abierto (whapi sin firma).

Identificadores

Item	Valor
Commit	807a676
Mensaje	fix(seguridad): META_APP_SECRET obligatorio en produccion
Rama local	pr/meta-webhook-firma-obligatoria
Rama remota	origin/pr/meta-webhook-firma-obligatoria
Crear PR en GitHub	https://github.com/celestinojbm/Dona-agent/pull/new/pr/meta-webhook-firma-obligatoria
main local	58c806b (post-merge T0.2; igual a origin/main, INTACTO)
origin/main	58c806b (sin push de este PR a main)

Archivos tocados (los 3 autorizados, ninguno fuera de alcance)

Archivo	Cambio
agent/providers/meta.py	+ check en ProveedorMeta.__init__(): si ENVIRONMENT=production y app_secret vacio (post-.strip()) -> RuntimeError. Refactor de _verificar_firma: en produccion rechaza con False si no hay secret (defensa en profundidad); en dev/test mantiene path permisivo con warning. Lee ENVIRONMENT en cada llamada para tests con monkeypatch.
.env.example	+ bloque documental para META_APP_SECRET dentro del bloque Meta existente. Renombre META_VERIFY_TOKEN a META_WEBHOOK_VERIFY_TOKEN (la var real que lee el codigo en meta.py:99). Sin valores reales.
tests/test_providers.py	TestVerificacionHMAC ampliado: test_sin_secret_permite_todo se reemplazo por dos tests explicitos (test_sin_secret_en_dev_permite y test_sin_secret_en_test_permite) con monkeypatch.setenv. Agregada clase nueva TestVerificacionHMACProduction con 5 tests: RuntimeError en init sin secret, RuntimeError con secret whitespace, no levanta con secret valido, defensa en profundidad runtime, firma valida en produccion.

Total: 3 archivos, +121 lineas, -9 lineas.

Tests corridos

Suite	Resultado
pytest tests/test_providers.py -x -q	29 passed en 0.71 s
pytest -q (suite completa)	455 passed en 92 s, exit 0

Sin regresiones. Suite paso de 449 (post-T0.2) a 455 — +6 tests netos del PR (5 nuevos en TestVerificacionHMACProduction + 1 nuevo en TestVerificacionHMAC por el split del antiguo).

Comportamiento implementado

Escenario	Antes (P0 abierto)	Ahora
WHATSAPP_PROVIDER=meta + ENVIRONMENT=production + META_APP_SECRET vacio	Acepta sin firma -> atacante inyecta mensajes WhatsApp falsos	RuntimeError al instanciar ProveedorMeta -> obtener_proveedor() falla -> agent/main.py:54 aborta startup -> deploy aborta.
WHATSAPP_PROVIDER=meta + produccion + secret seteado	Validacion HMAC correcta	Sin cambios
WHATSAPP_PROVIDER=meta + produccion + firma invalida	Rechaza con 200+[]	Sin cambios
WHATSAPP_PROVIDER=whapi/twilio en produccion	ProveedorMeta ni se importa	Sin cambios — el check no afecta.
Dev/test sin secret	Permisivo con warning	Permisivo con warning (mismo comportamiento, log mejorado)
Path runtime: provider creado en dev y luego ENVIRONMENT cambia a production	No protege	Defensa en profundidad: _verificar_firma rechaza igual

Estado git

- **main local** en 58c806b, igual a origin/main. Intacto.
- **HEAD** en pr/meta-webhook-firma-obligatoria con 807a676.
- Sin push a main. Sin merge. Sin deploy.

Lo que NO toque (segun reglas)

- **agent/providers/whapi.py** — sin cambios (T0.10 sigue siendo tarea separada).
- **WHAPI_TOKEN, WHAPI_API_URL** — sin tocar en .env.example.
- **agent/main.py** — sin cambios (a diferencia de T0.2; aqui no hace falta import top-level porque obtener_proveedor() ya instancia el provider en el startup).
- Base de datos — sin cambios.
- Render / Vercel / secretos — sin cambios. El valor real de META_APP_SECRET no aparece en codigo, comentarios ni tests (los tests usan dummies como 'test_app_secret_dummy' o 'production_secret_dummy').

Proximo paso recomendado (no implemento sin OK)

- **Revisar el PR en GitHub** desde el link de la portada.
- **Antes de mergear**, doble-check rapido en Render: que WHATSAPP_PROVIDER=meta y META_APP_SECRET siguen presentes con el valor correcto. Ya confirmaste — esto es solo verificacion visual final.

- **Mergear** y observar Render logs en el primer deploy: si arranca normal, todo bien; si aparece 'RuntimeError: [META] META_APP_SECRET no configurado en produccion', revertir inmediatamente.
- **Enviar un mensaje de prueba** a Dona desde tu WhatsApp. Si llega, la firma es correcta. Si no, revisar logs por '[META] Firma HMAC del webhook NO coincide' (significaria mismatch entre el secret en Render y el de Meta Dashboard).
- **T0.10 (whapi sin firma) sigue abierto** — es tarea separada cuando lo decidas.

Branch lista para merge. La decision queda en manos del owner.